

國泰金融控股股份有限公司暨子公司

人工智慧(AI)服務應用管理要點

114 年 2 月 25 日 訂定
權責單位：科技應用治理部

第1條 目的

為發展負責任之人工智慧(以下稱「AI」)服務，並管理 AI 服務之發展應用與風險管理，維護客戶及金融消費者權益，實現可信賴 AI 治理願景，爰依「國泰金融控股股份有限公司暨子公司運用人工智慧(AI)治理政策」制定本要點。

第2條 適用範圍

本公司及各子公司(以下合稱「各公司」)自行建置或委由第三方業者開發，且部署於本公司或子公司之(地端或雲端)測試或正式環境之 AI 服務應用，均應遵循本要點。

各子公司如依其業法、自律規範或管理需求，另訂低於本要點規定之標準者，應依「各公司會簽國泰金控事項彙整表」辦理。

第3條 名詞定義

本要點之用詞，定義如下：

- 1、 子公司：係指本公司直接、間接控制之金融業子公司，惟不包含國外子公司或分公司，但法令另有規定者，不在此限。
- 2、 金融消費者：係指接受金融服務業提供金融商品或服務之人。
- 3、 人工智慧(AI)：係指透過大量資料學習，利用機器學習或相關建立模型之演算法，進行感知、預測、決策、規劃、推理、溝通等模仿人類學習、思考及反應模式之技術。
- 4、 生成式 AI(Generative AI)：係指可以生成模擬人類智慧創造之內容的相關 AI，其內容形式包括但不限於文章、圖像、音訊、影片及

程式碼等。

- 5、 人工智慧服務應用(以下稱「AI 服務應用」)：係指需求單位運用 AI 或生成式 AI 之相關服務應用規劃案件。

第4條 角色權責

本要點所列之權責單位，係指本公司數位數據暨科技發展中心科技應用治理部，權責如下：

- 1、 規劃集團 AI 治理政策及管理措施。
- 2、 訂定及修訂本要點與其他作業規範及附件。
- 3、 監督及掌握各公司 AI 服務應用情形，並辦理相關定期盤點作業。
- 4、 定期檢視集團各公司 AI 服務應用案件之發展情形。

其他依權責或經核定應辦理之事項。本要點所列之金融科技應用審查委員會(以下稱「委員會」)，係指依「國泰金融控股股份有限公司金融科技應用審查委員會組織要點」所組成者，並就本公司 AI 服務應用管理部分之權責如下：

- 1、 負責本公司 AI 服務應用案件之相關風險評估及審查。
- 2、 督導需求單位及開發單位妥善規劃本公司 AI 服務應用，協助評估單位共同評估相關 AI 服務應用案件之風險及管理控制措施。

本要點其他相關單位，權責如下：

- 1、 需求單位：係指本公司或子公司有 AI 服務應用需求之單位，需求單位應負責 AI 服務應用之需求申請準備（包括填寫 AI 服務應用風險評估表與上線檢核表等）、案件審查提報說明及 AI 服務應用上線後定期驗證的執行。
- 2、 開發單位：係指本公司或子公司協助開發 AI 服務應用需求之單位，開發單位應負責 AI 服務應用之模型開發，並協助需求單位完成該案件審查之相關準備。
- 3、 評估單位：係指本公司或子公司協助共同審查 AI 服務應用需求規劃之單位，評估單位應負責審查需求單位所提出之 AI 服務應用需求申請，並檢視該案之風險評估表與上線檢核表等文件。評估單位應包括但不限於雲端策略發展部、數據暨人工智慧發展部、資訊處、資訊安全處、風險管理處、科技應用治理部、法務室及法令遵

循處。

子公司得依其業法或管理需求，明定其權責單位、需求單位、開發單位、評估單位、審查層級及程序等相關單位或組織，以協助辦理該子公司之 AI 服務應用管理相關事宜；各子公司如依其業法、自律規範或管理需求，另訂低於本要點規定之標準者，應依「各公司會簽國泰金控事項彙整表」辦理。

第5條 AI 服務應用之風險評估

AI 服務應用風險評估，應依下列規定辦理：

- 1、各公司應以風險為基礎方法辦理 AI 服務應用之風險辨識、評估及控管程序。
- 2、各公司 AI 服務應用之風險評估方法（參附件一）：係就 AI 服務應用所採用之 AI 模型固有風險程度及其應用場景影響程度等相關風險因子所彙總之風險矩陣，綜合考量其他相關必要風險評估及檢核項目。
- 3、本公司 AI 服務應用之風險評估結果及分級審查程序：

風險評估結果	分級審查層級
高風險	總經理 (或經總經理授權指定之人或組織)
中風險	金融科技應用審查委員會 (或經總經理授權指定之人或組織)
低風險	需求單位或權責單位督導主管 (或經總經理授權指定之人或組織)

- (1) 風險評估結果為高風險者，應經委員會審查，並呈報總經理審查通過。
- (2) 風險評估結果為中風險者，應呈報委員會審查通過。
- (3) 風險評估結果為低風險者，應呈報需求單位或權責單位督導主管審查通過。
- (4) 子公司得依其業法或管理需求，自行調整以上分級審查層級，惟不得低於本要點規定；各子公司如依其業法、自律規範或管理需求，另訂低於本要點規定之標準者，應依「各公司會簽國泰金控事項彙整表」辦理。

「國泰金控事項彙整表」辦理。

4、本公司 AI 服務應用相關案件之風險評估程序：

- (1) 相關案件應由需求單位洽評估單位辦理 AI 服務應用之風險評估，並填具「AI 服務應用案件檢核暨風險評估表」（參附件二）。
- (2) 就涉及個人資料使用部分，應檢附經風險管理處檢視確認之檢核結果。
- (3) 如規劃適用雲端委外規定者，亦應依本公司「雲端委外作業管理辦法」，填具「雲端委外案件檢核暨風險評估表」，並洽評估單位評估確認。
- (4) 如規劃使用金控雲端環境者，亦應依本公司「雲端專案上線與變更管理辦法」，填具「雲端上線/變更檢核表」，並洽相關單位確認，經本公司雲端變更審查小組(CAB)審查通過。
- (5) 如規劃使用金控地端環境者，應依本公司資訊處地端上線檢核表相關管控措施辦理。
- (6) 需求單位檢附之相關文件，均應先經需求單位部門主管同意後再送交相關評估單位確認。
- (7) 於同時填具第一款至第三款其一並有不同風險者，應洽評估單位評估確認，並應從嚴認定其所適用分級審查程序。
- (8) 子公司得依其業法或管理需求，自行調整以上風險評估程序，惟不得低於本要點規定；各子公司如依其業法、自律規範或管理需求，另訂低於本要點規定之標準者，應依「各公司會簽國泰金控事項彙整表」辦理。
- (9) 相關案件除前揭風險評估程序外，仍應依本公司分層負責表及其他相關內部規範(包括但不限於資安、採購等)辦理。

5、本公司之「AI 服務應用風險評估方法」（附件一）及「AI 服務應用案件檢核暨風險評估表」（附件二），應由權責單位會同評估單位共同訂定，且應定期會同評估單位啟動相關檢視修訂作業。

6、AI 服務應用案件如有應用場景異動、重大變動或因法令致生重大影響等情形發生，需求單位即應重新辦理 AI 服務應用之風險評估、分級及審查。

第6條 定期驗證

AI 服務應用如經前條程序審查完成並正式上線後，需求單位應定期驗證其 AI 模型效度 (Validity) 。如效度低於設定之門檻標準，需求單位及開發單位應提出精進措施或其他因應計劃。

前項模型效度之定期驗證頻率，依 AI 服務應用案件之風險評級，區別如下：

AI 服務應用風險評級	AI 模型效度 (Validity) 驗證頻率
高風險	一年一次
中風險	二年一次
低風險	三年一次

第7條 第三方業者服務管理

各公司導入第三方業者提供之 AI 服務應用前，宜評估其知識專業及過往經驗，並依相關採購規定辦理遴選、議價等採購作業。

各公司如委託第三方業者導入 AI 服務應用，宜簽訂書面契約，明定專案導入範圍、第三方業者責任範疇、留存受託事項之執行紀錄、未達契約約定標準之處理方式，及就停止委託之情形訂定適當之資料或系統遷移機制。

前項委託如涉及客戶資料傳送予第三方業者之情形，應於契約明定資料保護條款之協議，包含資料加密傳輸、存儲安全或服務終止後資料之處置方式。

第8條 替代方案及救濟選項

各公司所運用之 AI 服務應用如涉及客戶或金融消費者，宜視技術可行性、成本效益分析等相關因素，決定是否提供替代方案，以尊重其是否選擇使用 AI 服務應用之權利；如有提供替代方案，應於該金融服務流程揭露。

各公司所運用之 AI 服務應用，如服務對象為客戶或金融消費者，應揭露客服專線或其他救濟選項。

第9條 對外揭露

各公司所運用之 AI 服務應用如涉及直接與客戶或金融消費者互動，宜於該金融服務流程中適當揭露相關資訊，惟如用於洗錢防制、資訊安全、詐騙偵防、涉及營業秘密之應用場景者，得免予揭露。

第10條 員工訓練

各公司宜定期提供專業培訓或教育訓練資源予負責 AI 技術及治理之相關部門及人員，以提升人員對 AI 服務導入、運用、管理之能力。

第11條 通報

各公司所運用之 AI 服務應用，如模型產出結果錯誤或模型服務中斷，或發生資料外洩、違反個人資料保護法之情事，應依既有之資安、風險、個資外洩、重大事件等相關事件通報流程進行通報，並應另以公文呈報本公司權責單位，以利後續監督追蹤改善情形。

第12條 附則

本要點如有未盡事宜，悉依內、外部相關規範辦理。

第13條 施行

本要點之訂定、修正或廢止，經總經理核定後生效。

本要點附件之訂定、修正或廢止，授權經本公司權責單位督導主管核定後生效；惟附件一之訂定、修訂或廢止應先會辦評估單位督導主管。

附件一、AI服務應用風險評估方法（版本：2025/XX/XX）

一、 AI服務應用風險評估：係以「AI模型固有風險程度」及「AI服務應用場景影響程度」兩個面向之風險因子，經分別評估後(詳以下「(一)」及「(二)」)，所彙總之風險矩陣(詳下表)來綜合評估判斷。

AI服務應用風險評估結果		AI模型固有風險程度	
		低風險	中風險/高風險
AI服務應用場景影響程度	高風險應用場景	中風險	高風險
	非高風險應用場景	低風險	中風險

(一)「AI模型固有風險程度」之判斷方法說明：
係以AI模型主要固有風險「AI自主決策程度」及「AI產出不確定性程度」所組成之風險矩陣綜合判斷。

AI模型固有風險程度		AI模型產出不確定性程度	
		低風險 (AI產出內容可預期)	高風險 (AI產出內容不可預期)
AI模型自主決策程度	高風險 (over the loop)	中風險	高風險
	低風險 (非over the loop)	低風險	中風險

- 1、「AI模型自主決策程度」之判斷方法說明：
- (1) 高風險：即AI模型運作係屬人在迴圈上(Human-over-the-loop)之決策監督機制，人類僅於AI模型遭遇意外或不良事件（例如模型失敗）時，才接管控制模型並在運算過程中調整參數，故AI模型自主決策程度相關風險評估為較高。
- (2) 低風險：非上述情形者，即AI模型運作係屬人在迴圈內(Human-in-the-loop)或人在指揮(Human-in-command)之決策監督機制，人類於決策過程中主動參與監督/直接指揮監督AI模型運作，AI模型並無自主決策，故相關風險評估均較低。
- 2、「AI模型產出不確定性程度」之判斷方法說明：
- (1) 高風險：AI模型之產出為不可預期之內容，故AI模型產出不確定性相關風險為較高，例如：使用生成式AI技術之模型（每次輸入相同內容均產出不同的回覆）。
- (2) 低風險：AI模型之產出為可預期之內容，例如：Chatbot所運用之AI模型係以rule-based形式於預先給定的資料範圍內揀選答覆、信貸額度評估所運用之AI模型係依據給定之參數來提供額度
- 應依下列方式判斷：
- ＊註：AI指引風險評估因素所列之AI系統複雜性，係指運算模型的複雜性較高或使用參數數量與類型較多的AI系統，可能降低可解釋性，而有較高之風險性。考量模型產出的結果如為不可預期（給定相同內容均產出不同的回覆），因其產出具備不確定性、隨機性，其模型複雜程度相對較高，可解釋性的程度相應較低，因此有較高之風險，故以模型產出之不確定性作為判斷指標。

- (二) AI服務應用場景影響程度的判斷方法說明：
- 1、配合AI服務應用場景面對不同的利害關係人之面向，區分為面對「客戶或金融消費者」、「公司營運」或「員工」可能造成重大影響的評估標準；再依所屬面向評估標準判斷是否符合，如判斷有符合者，即評估屬對該利害關係人可能造成重大影響具較高風險之類型；如判斷皆無符合評估標準者，即評估屬對該利害關係人可能造成重大影響具較低風險之類型。
- 2、在AI服務應用場景所屬利害關係人面向中，如評估有任一項評估標準符合即屬高風險應用場景，皆無符合者方屬非高風險應用場景。
- 3、如AI服務應用場景涉及多個面向，如評估有任一項評估標準符合即屬高風險應用場景，皆無符合者方屬非高風險應用場景。
- 4、優先法高風險：如屬依法令須向主管機關報准/報備者，應直接視為高風險應用場景。

影響利害關係人 (Stakeholder) 面向	可能對該利害關係人造成較高風險影響之評估標準
1.客戶或金融消費者	1.1 涉及客戶或金融消費者業務申辦或交易執行之 決策者 。
	1.2 其他對客戶或金融消費者有較高風險影響情形者(得由子公司自行增訂)。
2.公司營運	2.1 涉及核心資通系統之 決策者 。
	2.2 涉及關鍵業務流程之 決策者 。
	2.3 涉及監理規範要求所為之 決策者 。
	2.4 其他對公司營運有較高風險影響情形者(得由子公司自行增訂)。
3.員工	3.1 涉及員工之升遷、辭退、薪酬、績效評估或工作項目分配之 決策者 。
	3.2 其他對員工有較高風險影響情形者(得由子公司自行增訂)。

補充說明：

- (一) 子公司得依其業法或管理需求，自行增訂相關評估標準，惟相關管控不得低於本要點規定。
- (二) 對客戶或金融消費者服務有較高風險影響之 AI 服務應用情境，例如：
- ① 金融交易業務，如：存放款、轉帳交易驗身。
- ② 信用卡業務，如：核卡與否。
- ③ 授信業務，如：徵審核駁。
- (三) 對營運有較高風險影響之 AI 服務應用情境，例如：
- ① 涉及核心資通系統之決策。
- ② 涉及關鍵業務流程之決策，如：金控股務、短期資金分析。
- ③ 涉及監理規範要求所為之決策(如：資本計提計算)、洗錢防制系統中因監理規範要求所為之自動化決策並影響客戶權益且無人介入者(譬如：AI 服務應用之自動化決策情境，係因監理規範要求而對客戶有不受理或禁止交易等影響客戶權益之情形，且亦無人介入此AI服務應用之自動化決策)。
- (四) 對員工有較高風險影響之 AI 服務應用情境，例如：
- ① 員工績效/薪資/升遷/PIP 之評核判斷

附件二、AI服務應用案件檢核暨風險評估表（版本：2025/XX/XX）

總說明：

為妥善管理AI服務之發展應用與風險，故針對AI服務應用案件之相關風險評估項目及必要檢核項目彙總如本表，以供評估單位及層峰審查參考。

* 子公司得依其業法或管理需求，自行增訂或調整必要檢核項目及(應用場景)，惟相關管控不得低於本要點規定。

* 本表「評估單位」僅適用於金控，子公司得依本要點規定，視其業法或管理需求，自行指派相關單位或組織辦理。

填寫說明：

1.本表由需求單位填寫，開發單位協助，並應事先洽相關評估單位確認，需求單位如有需要亦得另附簡報或其他文件補充說明。

2.需求單位檢核及評估結果，須經評估單位確認同意，並依該案所屬審查層級及程序辦理。

3.適用上如有疑問，可先洽金控科技應用治理部聯繫詢問。

專案名稱：	需求單位：	填寫日期	yyyy/mm/dd
-------	-------	------	------------

壹、必要檢核項目

1.需求單位如經檢核有以下任一項必要檢核事項評估為「否」者，依相關規定將不得辦理，故團隊亦無須續填本表，如有適用疑義，可先洽詢相關評估單位。

2.必要檢核事項如經檢視為「是」者，後續風險評估項目仍可能有相關風險程度評估之必要性，故必要檢核項目僅就可能影響相關規劃不得辦理部分，先請須前單位檢核確認，並不納入後續風險總評分。

項次	檢核項目	檢核說明	補充說明	檢核結果	評估單位	評估意見
1	本案規劃是否符合本公司/集團AI服務應用策略目標？	AI服務應用策略目標：發展負責任式AI，有效管理相關風險、保護消費者權益。 - 運用AI服務提升營運效率、提升客戶體驗 - 建立完善問責機制，明確團隊各角色責任與權限 - 確保AI系統的決策公平公正，不歧視特定族群 - 保護隱私及客戶權益 - 確保系統穩健性與安全性 - 落實透明性與可解釋性		☐是 ☐否	科技應用治理部	☐同意 ☐不同意
2	本案是否已通過變更審查小組(CAB1)之雲端/雲端服務上線審查?(本項檢核，得於CAB1審查完成後再填寫)	變更審查小組(CAB1)之雲端服務上線審查包括以下項目： - 雲端服務之適當性 - 雲端服務之一般通用安全 - 系統權限管理檢視 - 映像檔管理 - 架構面設置 - 數據、資料管理 - 持續營運計畫 - 金控維運 - 適法性議題 參考規範： 國泰金融控股股份有限公司雲端生產環境管理辦法 雲端上線檢查表		☐是 ☐否	科技應用治理部 雲端策略發展部 資訊處 法令遵循處 法務室 風險管理處 資訊安全處	☐同意 ☐不同意

貳、風險評估項目

1.請參考附件一「AI服務應用風險評估方法」說明填寫，並先洽金控科技應用治理部初步評估確認。

2.需求單位如就各評估項目，有評估結果以外之補充說明需求者，可於「補充說明」欄位填寫(或註記另以簡報或其他文件補充等)。

3.評估單位就個別案件，如經檢視對個別風險評估結果或總評結果認應予以特別關注者，個別風險評估項目得經1/2以上(含)相關單位委員同意後予以調升、調降風險等級；風險程度總評結果得經2/3以上(含)全體委員同意後予以調升、調降風險等級，或補充說明相同/不同意見並留存紀錄。

項次	評估項目	各項評估情形	補充說明	評估結果	評估單位	評估意見
一、AI模型固有風險程度						
1	【AI自主決策程度】 AI模型產出的決策結果是否有人員介入？ 〔指引總則章三(三)〕	☐高風險(Over the loop) ☐低風險(非Over the loop)		☐高風險 ☐中風險 ☐低風險	科技應用治理部	☐同意 ☐不同意
2	【AI產出不確定性】 AI模型產出內容是否具不確定性？ 〔指引總則章三(四)之AI系統複雜性〕	☐高風險 ☐低風險				

二、AI服務應用場景影響程度

3	請說明本案AI服務應用場景影響之利害關係人(Stakeholder)？ 〔指引總則章三(五)〕	本案AI服務應用場景影響之面向： ○客戶或金融消費者【項次3.1必填】 ○公司營運【項次3.2必填】 ○員工【項次3.3必填】	(請需求單位詳述AI服務應用之場景/使用情境)			
3.1	對客戶或金融消費者是否造成較高風險之影響？ 〔指引總則章三(一)〕	○涉及客戶或金融消費者業務申辦與執行交易之准駁 ○其他對客戶或金融消費者有較高風險影響情形者 ○以上情形皆無 ○不適用		○高風險應用場景 ○非高風險應用場景 *如3.4勾選是，應直接視為高風險應用場景。	科技應用治理部 法令遵循處 法務室 風險管理處 資訊安全處	○同意 ○不同意
3.2	對公司營運是否造成較高風險之影響？ 〔指引總則章三(一)〕	○涉及核心資訊系統之決策 ○涉及關鍵業務流程之決策 ○涉及監理規範要求所為之決策 ○其他對公司營運有較高風險影響情形 ○以上情形皆無 ○不適用			科技應用治理部 法令遵循處 法務室 風險管理處 資訊安全處	○同意 ○不同意
3.3	對員工是否造成較高風險之影響？	○涉及員工升遷、辭退、薪資、績效評估或工作項目分配之決策 ○其他對員工較高風險影響情形 ○以上情形皆無 ○不適用			科技應用治理部 (人力資源處)	○同意 ○不同意
3.4	本案是否屬依法令須向主管機關報准/報備之情形？	○否 ○是，請說明本案報准/報備內容。	(請詳述報准/報備內容)		法令遵循處	○同意 ○不同意
三、其他風險評估項目						
4	對客戶或金融消費者/員工提供之AI服務應用，是否有提供客戶或金融消費者/員工退出使用AI服務之替代措施？ 〔指引第三章四(二)〕	○有(請詳述替代措施) ○無(請詳述評估理由，包括經評估危害程度、技術可行性、成本效益分析等相關因素後，不予提供替代措施)	(請詳述替代措施/評估理由)	○應提升一級風險 ○維持原風險	科技應用治理部 法令遵循處 法務室 風險管理處 資訊安全處	○同意 ○不同意
5	請說明本案AI服務應用所提供之救濟選項。 〔指引總則章三(六)〕	○無，本案係與洗錢防制或詐騙偵防有關，故本案得不提供替代措施。 〔指引第二章二(三)〕 ○無，本案非涉及客戶或金融消費者。 〔指引第二章二(三)〕 ○本案已提供救濟選項(申訴專線、補救管道、爭議處理機制等)並說明	(請詳述救濟選項)		科技應用治理部 法令遵循處 法務室 風險管理處 資訊安全處	○同意 ○不同意

AI服務應用案件	風險評估結果/審查層級	補充意見說明	
○通過 ○不通過	○高風險 ○總經理 ○中風險 ○金融科技應用審查委員會 ○低風險 ○需求單位督導主管		
填寫單位（處部科全銜）	填寫單位部級(以上)主管	填寫單位覆核人員	填寫單位承辦人員
			分機：
評估單位	評估單位督導主管	評估單位覆核人員	評估單位承辦人員
科技應用治理部			
資訊安全處			
風險管理處			
法令遵循處			
法務室			
人力資源處 (僅涉及3.3重大影響者適用)			